

Hacker vs Database - La sfida

Il bersaglio

I database sono il "caveau" digitale



Il bersaglio: I database sono il "caveau" digitale. Contengono credenziali, dati personali e segreti industriali.

L'approccio: Un hacker non cerca di abbattere il database, ma di **ingannarlo**.

Il problema: Molti attacchi avvengono perché il database non distingue tra un comando legittimo del programmatore e un comando malevolo inserito da un utente.

SQL Injection (L'attacco "Camaleonte")



Cos'è

L'hacker inserisce frammenti di codice SQL nei moduli di input (come la barra di ricerca o il login).



L'esempio classico

Invece di scrivere il nome, l'hacker scrive: `' OR 1=1 --`



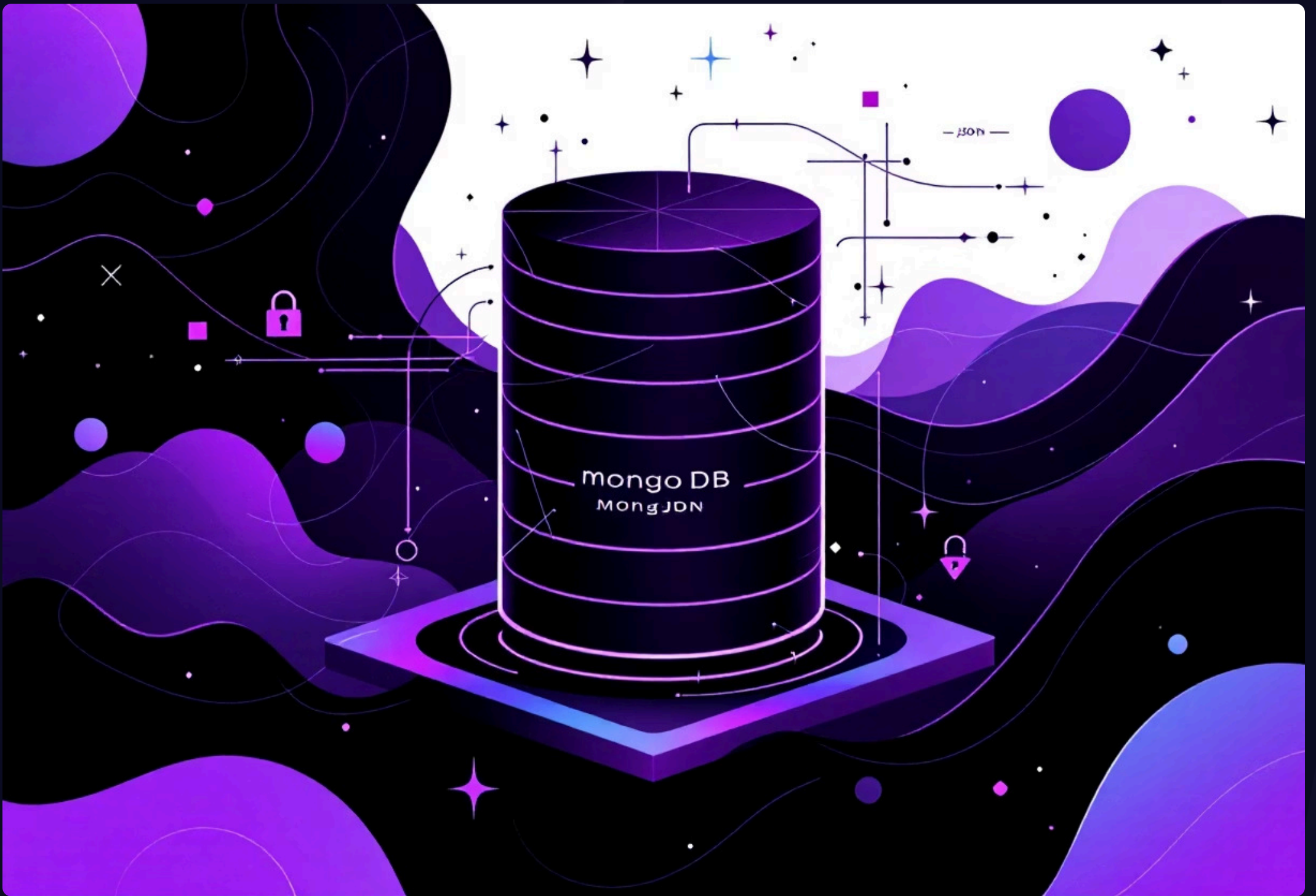
Perché funziona?

Perché $1=1$ è una condizione sempre vera. Il database "pensa" che l'identità sia confermata e permette l'accesso senza password.



Danni: Furto di interi database (Dump), modifica dei dati o cancellazione delle tabelle.

NoSQL Injection (Attacchi alla logica JSON)



Il mito

"I NoSQL sono immuni perché non usano SQL". **FALSO.**

L'attacco

Si sfruttano gli operatori speciali (come quelli di MongoDB).

Esempio

Input inviato: `{"username": {"$gt": ""}}`

Cosa succede: \$gt significa "Greater Than" (maggiore di). L'hacker sta dicendo al DB: "Accedi se lo username è maggiore del vuoto". Risultato? Accesso garantito.

Rischio: Molto alto perché molti sviluppatori pensano (erroneamente) che il NoSQL sia sicuro "per natura".

Data Exfiltration e Ransomware

Exfiltration

Una volta dentro, l'hacker usa query per "succhiare" i dati lentamente per non farsi scoprire dai sistemi di monitoraggio.

Ransomware sui DB

Nei DB NoSQL (come Redis o MongoDB) spesso non viene impostata una password di default.



Passo 1

L'hacker trova il DB aperto su internet.



Passo 2

Copia i dati e cancella l'originale.



Passo 3

Lascia una tabella chiamata READ_ME con la richiesta di riscatto in Bitcoin.

Difesa - Le "Mura" del Database

01

Prepared Statements (Parametrizzazione)

È la difesa #1 contro SQL Injection. Si dice al DB: "Aspettati solo un nome, ignora ogni comando extra".

02

Input Validation

Se il campo richiede una data di nascita, il sistema deve rifiutare simboli come \$ o '.

03

Principio del Minimo Privilegio

L'utente che gestisce il sito web non deve avere i permessi per cancellare il database (DROP), ma solo per leggere e scrivere.

04

Cifratura (Encryption)

I dati sensibili devono essere illeggibili sul disco. Se l'hacker ruba il file, non può usarlo.

Checklist per l'Analista Cyber

- Il database è protetto da un Firewall?
- Esiste una password complessa per l'amministratore?
- Il codice dell'app usa "Prepared Statements"?
- I log sono attivi per vedere chi ha fatto cosa?
- I dati sensibili (password, CC) sono cifrati?